

Privacy Policy – Inveniam NVNM Chain MCP Service

This Privacy Policy (the "**Policy**") governs the collection, use, disclosure, and retention of information in connection with the public production deployment of the Inveniam NVNM Chain Model Context Protocol ("**MCP**") server (the "**Server**" or the "**Service**"), operated by **NVNM MCP, LLC** (the "**Operator**," "**we**," "**us**," or "**our**"). The Service enables AI agents and conversational AI clients (including Anthropic's Claude and OpenAI's ChatGPT) to read public Inveniam Chain state and to prepare and broadcast pre-signed transactions on the caller's behalf.

Scope — read/write authentication model. The production Service applies a **keyless-read, authenticated-write** model. Read tools (anchor verification, EVM reads, the overview / wallet-status / setup helpers) run **without authentication** and collect no per-customer identifier. Preparing a transaction is unauthenticated; broadcasting a signed transaction — `evm_send_raw_transaction`, the only tool that effects an on-chain write — requires authentication. The transaction-construction tools (`anchor_prepare_*`) return unsigned bytes only and are unauthenticated.

1. Operator Identification

Field	Value
Legal entity (Controller)	NVNM MCP, LLC
Governing jurisdiction	United States (Delaware)
Privacy / Security contact	<code>security@inveniam.io</code>
Mailing address	108 West 13th Street Suite 100, Wilmington, Delaware, New Castle County
Production endpoints	<code>mcp.nvnmchain.io</code> (mainnet, chain ID 1611); <code>mcp-testnet.nvnmchain.io</code> (testnet, chain ID 787111)
Effective date	June 8, 2026
Repository (publisher identity only)	<code>github.com/NVNM-Chain/nvnm-mcp-server</code>

A **single legal entity** controls both the mainnet and testnet instances. The two instances run identical data-processing code and are covered by this one Policy. NVNM MCP, LLC is the entity responsible (the data controller) for the processing described in this Policy.

2. What the Service is, and what it is not

The Service is a stateless gateway that lets you read public on-chain data and submit pre-signed transactions to the Inveniam Chain. **The Service never holds your private keys, never signs on your behalf, and never takes custody of your funds.** Its verified architectural properties:

- **Stateless read path.** Read tools issue JSON-RPC calls directly to the configured Inveniam Chain EVM endpoint.
- **Stateless onboarding.** The setup wizard derives onboarding status from on-chain truth (balance and nonce), not from any Server-side database.
- **Prepare-sign-submit writes.** Write tools build unsigned transactions Server-side; the caller signs locally and submits the signed bytes via `evm_send_raw_transaction`.

- **Non-custodial relay.** The Server's transaction-building tools construct only Inveniam anchor-precompile transactions. The broadcast tool relays any transaction you have already signed yourself.
- **Anchor precompile.** The anchor-write tools target the chain precompile at the fixed address 0x00000000000000000000000000000000A00.
- **No document handling.** The Server has no file-ingestion surface; it handles only the hash string and any user-supplied pointer URI.

The read/write asymmetry is deliberate and is the core privacy design. The Inveniam Chain's value proposition is cryptographic proof of content state at a point in time. The Service preserves that public-verification property by **not** gating reads behind a credential. A read-only user needs **no NVNM Chain account, wallet, or credential of any kind** — reads operate entirely against public chain state.

We do **not** maintain general user accounts in the consumer-Internet sense (no behavioral profile, no preferences store, no marketing record). We **do** maintain a **credential record** for each customer who can make write requests — either an API-key entry (SHA-256-hashed at rest) or a user record held by our identity-provider sub-processor — solely to authenticate write requests and honor revocation. That credential record is the minimum customer registry necessary to operate the write path; it is not a profile.

3. Information We Collect

Read traffic and write traffic differ sharply: reads carry no per-customer identifier; writes are authenticated and do.

3(a) Inputs to MCP tools (caller-supplied)

Each of the twenty-one (21) tools accepts only the inputs below. Detailed tables are maintained in the technical reference (DATA_HANDLING.md). Only the broadcast tool (evm_send_raw_transaction) requires authentication; all other tools — reads and transaction-construction — are unauthenticated.

Overview and setup tools (read; unauthenticated)

- nvnm_overview — (none)
- nvnm_setup_wizard — address (optional EVM address)
- nvnm_setup_verify_hash — address; your_hash (SHA-256 hex)
- nvnm_setup_verify_signature — address; signature (65-byte EIP-191 hex)
- wallet_status — address

EVM read tools (unauthenticated)

- evm_get_chain_id, evm_get_block, evm_get_transaction, evm_get_transaction_receipt, evm_get_balance, evm_get_code, evm_get_logs, evm_call_contract

Anchor read tools (unauthenticated)

- anchor_info, anchor_get_registry, anchor_get_registries, anchor_get_records

Transaction-construction tools (unauthenticated)

- anchor_prepare_add_registry, anchor_prepare_add_record, anchor_prepare_grant_role — construct unsigned transactions; return bytes only; no authentication, no per-customer identifier.

Write / broadcast tool (authenticated)

- evm_send_raw_transaction — the only tool that effects an on-chain write, and the only write-path tool that authenticates and records a per-customer identifier.

3(b) Outputs returned to the MCP client

The Server normalizes JSON-RPC results into typed shapes. Every response also carries a server-authored `next_actions` envelope guiding chained calls. After a successful `evm_send_raw_transaction`, one `next_actions` entry echoes the transaction hash of the just-broadcast transaction.

3(c) Server-side persistence

Read traffic writes nothing to disk. The setup-wizard per-address verification challenge is computed on the fly and never persisted. The only auth-layer persistence surface is the API-key store (`MCP_API_KEYS_FILE`): for customers who authenticate writes with an Operator-issued API key, we store one SHA-256-hashed key entry per credential, with its assigned roles. We never store the plaintext key after issuance.

Customer onboarding. When you register to obtain a write credential via the self-serve key-request endpoint, we collect your email address (required), organization name (optional), and a short free-text description of what you intend to build (required). We do not collect billing information at this time.

3(d) Operational telemetry

To run the Service reliably and securely, we record basic operational information about each request. We never record the contents of your tool calls or their results — only the facts needed to operate and secure the Service. For every request we record the operation name, a random request identifier, how long it took, and whether it succeeded. On write requests (which are authenticated) we also record a per-customer identifier so we can attribute usage, enforce limits, honor revocation, and investigate abuse. On read requests (which are unauthenticated) there is no per-customer identifier to record. On failed sign-in attempts or rejected connections we additionally record the caller's IP address, and we count repeated failed sign-ins over a rolling 15-minute window to throttle attacks.

The per-customer identifier on write requests is **not** your name or email. For API-key customers it is the label assigned to your key. For single-sign-on customers it is produced by a one-way, keyed transformation (HMAC) of your sign-in identifier. The result stays consistent so we can correlate your own requests for audit purposes, but it **cannot be turned back into your real-world identity** without separately-held keys.

3(e) Authentication metadata

Read requests require no credential and establish no identity. Write requests require a credential under one of two methods — an Operator-issued API key, or single-sign-on — from which we derive the per-customer identifier described in §3(d). We record reason codes and that derived identifier only; we never record the raw API key, the raw token, or your raw sign-in identifier.

4. Information We Do Not Collect

Each exclusion is verified against the production codebase:

- **Private keys** — no tool accepts one; signing is exclusively client-side
- **Seed/recovery phrases** — no mnemonic logic exists
- **Documents or files being anchored** — only the SHA-256 hash and any optional URI pointer reach the Server
- **Contents of any conversation with Claude, ChatGPT, or any other AI host** — the Server exposes no surface that reads host-side state
- **Raw tool-call arguments and return payloads in telemetry** — excluded at the middleware layer

- **Cookies, browser fingerprints, device identifiers, user-agent strings** — only remote_addr, and only on error / Origin-rejection / auth paths

5. Blockchain-Specific Disclosures

Read this section carefully before transacting.

- **Public and immutable.** Wallet addresses, transaction hashes, raw signed transactions submitted for broadcast, anchored SHA-256 hashes, and registry metadata may become part of the public, distributed Inveniam Chain ledger. Once committed, such data is public and immutable by the chain's design.
- **The Operator cannot delete or amend on-chain records.** No operator, including this one, can delete, redact, modify, anonymize, or rectify data committed to the chain; the Server exposes no tool capable of it.
- **Anchor writes are publicly observable.** The anchor precompile emits on-chain event logs for write operations: registry creation exposes the registry name, and record anchoring exposes the anchored SHA-256 hash, in the public transaction logs — readable by any chain observer, independent of the queryable registry state. Treat anything you anchor as public. If a registry name, hash pre-image, or pointer URI is sensitive, encode or salt it before anchoring; the Service relays exactly what you supply.
- **Hashes as personal data.** A SHA-256 hash may itself be personal data under the GDPR / UK GDPR and similar regimes where it can be linked to a natural person by a party holding the pre-image or sufficient context. Evaluate that re-identification risk before hashing and anchoring content.
- **User responsibility.** You are solely responsible for confirming that content you hash and anchor contains no personal or confidential data for which you must retain deletion/rectification ability. Because the resulting on-chain record cannot be removed by the Operator, the GDPR Article 17 right to erasure cannot, as a practical matter, be exercised against on-chain data through the Operator.
- **Public visibility of balances and nonces.** The gas-paying wallet address, its token balance, its nonce (which reveals cumulative activity), and associated transactions are publicly visible on the chain block explorer.

6. Purposes of Processing, and Legal Bases

We process the §3 categories solely to: (a) respond to MCP tool calls (forward to RPC, normalize responses); (b) construct unsigned transactions for write tools; (c) broadcast signed transactions on evm_send_raw_transaction; (d) perform Origin validation; (e) operational observability via aggregate metrics, without payload content; (f) abuse detection and security debugging via the §3(d) log fields; and (g) compliance with applicable law.

We do **not** use information collected through the Server for advertising, profiling, marketing, sale or sharing of personal information, or training of AI/ML models.

GDPR Article 6(1) legal bases: performance of a contract (Art. 6(1)(b)) for purposes (a)–(e); the Operator's legitimate interests in operating, securing, and improving the Service (Art. 6(1)(f)) for purposes (f)–(g); and compliance with legal obligations (Art. 6(1)(c)) for purpose (h).

7. Subprocessors and Disclosures to Third Parties

We do not sell your data or share it for marketing or analytics. We route data to the sub-processors below, each bound by written agreement to confidentiality and data-protection obligations consistent with §6.

Category	Role / data seen	Vendor
AI host surfaces	Carry MCP tool calls and responses between host AI client and Server	Anthropic, PBC; OpenAI, OpCo, LLC
Hosting, log sink, TLS	Compute hosting; receipt of structured logs (CloudWatch); TLS certificates	Amazon Web Services, Inc. — US region
24/7 NOC	Infrastructure monitoring and incident response with read access to CloudWatch logs	Innovative Solutions
Identity provider (SSO)	Validates single-sign-on tokens AND HOLDS the user record for customers authenticating via SSO	FusionAuth, Inc. (fusionauth.io) – managed cloud service
Inveniam Chain EVM RPC	EVM JSON-RPC connectivity (primary + archive) for anchor-proof verification	NVNM Labs Limited, a BVI company limited by shares (an affiliate of NVNM Labs LLC); intra-group data processing agreement in place
Public Inveniam Chain	Recipient of every broadcast transaction and anchored record	Inveniam Chain validator set

We may also disclose information where required by law, court order, or regulatory directive, or in good faith to protect our rights or the safety of others.

8. Data Retention

On-chain data is permanent and outside the Operator's control. Off-chain retention:

Category	Retention
Structured logs (stderr → CloudWatch), incl. write-path client_id	90 days
Observability traces	30 days
Observability metrics (aggregate)	90 days
Log archive / long-term backup	Not retained
Credential record (API-key entry or SSO user record)	While account active; deleted on verified request
Administrative audit trail (key created/revoked/role granted)	12 months (even after account closure)
Read-traffic per-customer records	None
On-chain data	Permanent (not within Operator's control)

9. User Rights and Deletion

Subject to applicable law, you may request access to, rectification of, deletion of, restriction or objection to processing of, or a portable copy of, the personal data we hold about you; and you may lodge a complaint with your data-protection authority. None of the processing in §6 relies on consent. The Service makes no automated decisions producing legal effects about you.

The off-chain data linkable to a specific customer is the write-path client_id and source IP in the operational logs, the credential record (§3(c)), and any onboarding data — held in our log sink and identity infrastructure (§7). Such records may be purged on verified request, subject to the §8 retention periods and the administrative-audit-trail exception.

To exercise a right, contact us at the address in §1. We will acknowledge a verifiable request within ten (10) business days and respond substantively within 30 days of identity verification, extendable by up to two further months for complex or numerous requests in accordance with GDPR Article 12(3). As described in §5, the Operator **cannot** delete, rectify, or modify data already committed to the Inveniam Chain.

10. Security

The Operator maintains administrative, technical, and physical safeguards, including:

- **Transport security.** The MCP HTTP transport is fronted by HTTPS at the Operator's ingress with a strict-but-compatible posture: TLS 1.2 minimum with TLS 1.3 enabled, HSTS enabled, and certificates issued via AWS Certificate Manager.
- **Authenticated broadcast.** The broadcast tool (`evm_send_raw_transaction`) requires a Bearer token under one of two providers (Operator-issued API key or single-sign-on JWT); credentials are stored SHA-256-hashed at rest, never in plaintext.
- **Origin allowlist.** The HTTP transport enforces an Origin allowlist on every request (the DNS-rebinding defence required by the MCP specification).
- **Brute-force throttling.** Repeated failed authentication attempts are counted in a 15-minute in-memory window per source and throttled.
- **Log redaction.** Credential material (Bearer tokens, JWTs, raw API keys) is never logged; the JWT subject claim is never logged in raw form; wallet addresses are truncated to first-six/last-four.
- **Non-custody.** The Server has no signing surface, generates no key material, and never holds private keys or seed phrases.
- **Container hardening.** Distroless image, non-root user, read-only root filesystem, all Linux capabilities dropped.

The keyless-read posture is itself a privacy safeguard: by not authenticating reads, we generate no per-customer record of read activity. No method of transmission or storage is fully secure, and the Operator cannot guarantee absolute security.

11. Anthropic-Specific Compliance Statements

(a) the Server collects only data necessary to perform its disclosed tool functions, and does not collect, store, or log conversation data, prompts, or anything beyond what §3 enumerates; (b) the Server does not query, request, extract, derive, or process Claude's memory, chat history, conversation summaries, or any user-uploaded files; and (c) the Operator and its affiliates own or control every API endpoint to which the Server makes outbound server-to-server connections — namely the EVM JSON-RPC endpoint (primary and archive), the identity provider, and, where configured, the telemetry collector. URLs surfaced to the user by the setup wizard (bridge.nvnmchain.io, docs.nvnmchain.io, and the block explorer) are rendered for display only; the Server makes no server-to-server requests to them. The public Inveniam Chain network to which signed transactions are broadcast is a decentralized validator set that the Operator does not own or control; it is disclosed as a recipient in §5 and §7, and broadcasting to it is the on-chain operation the user requests.

12. OpenAI-Specific Compliance Statements

(a) every category of user-related data the Server returns to the client is disclosed in §3(b); and (b) the Operator maintains the retention policy published in §8 and will honor verified deletion requests for off-chain data within the §9 timeframe.

13. Children

The Service is directed to businesses and software agents acting under authorized credentials. The Operator does not knowingly collect personal data from anyone under 13, or under the applicable age of digital consent (16 under the GDPR). If the Operator learns it has collected such data without verified parental/guardian consent, it will take reasonable steps to delete it.

14. International Transfers

The Service is operated from the United States on AWS US-region infrastructure. Where personal data is transferred from the European Economic Area, the United Kingdom, or Switzerland to a jurisdiction not deemed adequate, such transfers are made on the basis of appropriate safeguards, which may include the European Commission's Standard Contractual Clauses and, where applicable, the UK International Data Transfer Addendum.

15. Changes to this Policy

The Operator may update this Policy. No material change to data practices will take effect before the updated Policy is published at the hosting URL; the revision date at the top will move with any change, and prior versions will remain accessible by URL for not less than twenty-four (24) months after supersession.

16. Contact

Questions, requests, or complaints may be directed to:

NVNM MCP, LLC

Attn: Privacy Officer

108 West 13th Street Suite 100,

Wilmington, Delaware, New Castle County

Privacy / Security: security@inveniam.io

— *End of Draft Privacy Policy* —